EVALUACIÓN DE RIESGOS

1. Vulnerabilidades estratégicas del negocio (alto nivel)

1.1 Dependencia crítica de Azure

- Un solo proveedor
- No hay multicloud ni redundancia
- Riesgo: Caídas, errores de configuración, dependencia contractual
- Impacto: Alto

1.2 Falta de documentación formal en seguridad

- IR Plan en desarrollo
- Procesos no estandarizados
- Impacto: Medio

1.3 Madurez inmadura en respuesta a incidentes

- Procesos de entrenamiento iniciales
- No hay lecciones aprendidas implementadas
- Impacto: Medio-Alto

1.4 Baja capacitación del usuario (Phishing)

- Riesgo: Robo de credenciales, acceso inicial
- Impacto: Alto

1.5 Falta de red redundante real

- Packet Tracer es un diagrama, no una infraestructura configurada
- Impacto: Medio-Alto

1.6 Falta de BCP/DR formal

- No existe el Business Continuity Plan completo
- Impacto: Alto

VULNERABILIDADES DEL NEGOCIO

DEPENDENCIA CRÍTICA DE AZURE

Elemento	Descripción
ID del Riesgo:	IR-001
Amenaza:	Fallo total o interrupción prolongada del servicio en Azure (caída regional, outage general, error de configuración crítico del proveedor, ciberataque a Microsoft, indisponibilidad del control plane).
Vulnerabilidad asociada:	Mononube (Single Cloud) sin capacidades de redundancia o failover en otro proveedor. La continuidad depende totalmente de Azure.
Activo afectado:	Todas las cargas críticas: Azure App Service, Azure SQL Database, Active Directory Domain Services, Static Web Apps, Functions y toda la identidad corporativa.
Probabilidad:	Media (Azure es estable, pero los outages regionales ocurren varias veces por año).
Impacto en Confidencialidad:	Bajo → No necesariamente implica fuga de datos, solo indisponibilidad.
Impacto en Integridad:	Medio → Cambios no procesados, operaciones incompletas o pérdidas transaccionales si la caída ocurre en procesos activos.
Impacto en Disponibilidad:	Alto → Si Azure cae, la empresa queda completamente inoperante.
Impacto total:	Alto (la empresa depende al 90–100% de Azure para operar).

Elemento	Descripción
Nivel de Riesgo:	**Alto / Crítico**
Controles existentes:	• Backups automáticos de Azure SQL • Azure AD con redundancia interna • Herramientas nativas de recuperación de Microsoft • Monitoreo básico de estado del servicio
Controles recomendados:	• Diseño de *multi-region failover* dentro de Azure • Replicación en frío en otro proveedor (AWS, GCP) para cargas mínimas críticas • Implementar BCP/DRP • Evaluar contenedores/Microservicios portables formal • Pruebas regulares de recuperación ante desastres
Responsable:	CISO / Arquitecto de Infraestructura / AO
Prioridad de mitigación:	**Alta (1)** → Afecta la continuidad completa del negocio

FALTA DE DOCUMENTACIÓN FORMAL EN CIBERSEGURIDAD

Elemento	Descripción
ID del Riesgo:	R-002

Amenaza:	Procesos inconsistentes, errores operativos y respuestas inefectivas ante incidentes debido a ausencia de lineamientos formales.
Vulnerabilidad asociada:	Falta de políticas, procedimientos, estándares y guías formales que definan cómo se gestiona la seguridad.
Activo afectado:	Organización completa (procesos, personal, infraestructura, datos).
Probabilidad:	Media
Impacto en Confidencialidad:	Medio — decisiones improvisadas pueden llevar a fugas de información.
Impacto en Integridad:	Alto — sin procesos formales los datos pueden ser manipulados erróneamente o sin control.
Impacto en Disponibilidad:	Medio — fallos operativos o respuestas incorrectas pueden generar interrupciones.
Impacto total:	Alto
Nivel de Riesgo:	**Alto**
Controles existentes:	Documentos parciales; algunas prácticas no formalizadas; controles implementados pero sin estandarización.
Controles recomendados:	Crear políticas formales (IR, seguridad, acceso, datos), procedimientos operativos, estándares técnicos, guías de actuación; aprobarlos con AO; establecer un ciclo de revisión anual.
Responsable:	AO / CISO / Líder de TI
Prioridad de mitigación:	Alta

Elemento	Descripción
ID del Riesgo	R-003
Amenaza	Falla en gestionar eficazmente incidentes de seguridad
Vulnerabilidad asociada	Procesos de IR incompletos, falta de procedimientos, roles, documentación y métricas
Activo afectado	Operaciones de TI, servicios críticos, datos corporativos
Probabilidad	Alta
Impacto en Confidencialidad	Medio
Impacto en Integridad	Medio
Impacto en Disponibilidad	Alto
Impacto total	Alto
Nivel de Riesgo	Alto
Controles existentes	Primer borrador del IR Plan; recursos básicos del SOC interno; monitoreo inicial y antivirus
Controles recomendados	Finalizar y aprobar IR Plan; entrenar al personal; realizar simulacros; crear métricas de desempeño; estandarizar playbooks
Responsable	CISO / AO / Equipo de Respuesta a Incidentes
Prioridad de mitigación	Alta